

CSE722: Project 2 (Marks: 30%)

In this group project (use the same group formation from the previous project) you will design and implement a passwordless authentication web-service using the WebAuthn framework. The web-service must allow a user to register credentials on one device and subsequently authenticate from multiple browsers across multiple devices. The following requirements should be supported:

- i. You will deploy the web-service (either locally with HTTPS, you can use self-signed certificate or on a publicly accessible host) so that it can be reached from different browsers on multiple devices.
- ii. The server must be served over HTTPS (localhost is acceptable for development, but a valid TLS certificate is required for remote devices; you may use a self-signed certificate, or a tunnelling service such as ngrok/Cloudflare Tunnel). Mention in your report how you have managed this.
- iii. You will need to deploy the full WebAuthn flow as shown in the class using the webauthn.io demo.
- iv. You can register your WebAuthn credential using a platform authenticator (e.g. Windows Hello, Touch ID, Android biometrics), or a browser password manager or a roaming authenticator installed on mobile devices.
- v. Upon successful authentication, the user will be taken to a simple protected page that confirms the login and displays the username along with information about the authenticator used.
- vi. On the server side, attestation and assertion responses must be verified correctly, including the challenge, origin, RP ID hash, user-present / user-verified flags, and the signature. The signature counter must be checked and updated on each successful login.
- vii. Once deployed, you will need to test your service at least three browsers from your computer and at least three browsers from your mobile device. You will need to examine the issues that you are facing for each browsers in each devices, take screenshots of each successful or unsuccessful test-case, and present them in the report accordingly and clearly.
- viii. Also, demonstrate a negative test: attempt to log in using a credential that does not belong to the user, or tamper with the client data / signature, and show that the server rejects the request with a meaningful error.

Bonus (5 marks):

- i. The Relying Party (RP) ID, origin, and user handle must be configured correctly so that credentials created on one device can be used from another browser/device of the same user.

Before writing the code, you should study the WebAuthn registration (attestation) and authentication (assertion) ceremonies and document in your report which parts of the protocol your server verifies and how.

The project has the following deliverables:

- The WebAuthn web-service source code with detailed instructions on how to run it in a particular OS (including how to generate or install the TLS certificate). This needs to be uploaded to a GitHub repository.
- A report describing your WebAuthn implementation (RP configuration, registration and authentication flows, cryptographic verification performed on the server), the tests you carried out with screenshots from different browsers and devices, and the GitHub link.

References (WebAuthn tutorials)

- WebAuthn Guide by Duo Security: <https://webauthn.guide/>
- SimpleWebAuthn – Introduction and tutorial: <https://simplewebauthn.dev/docs/>
- MDN Web Docs – Web Authentication API: https://developer.mozilla.org/en-US/docs/Web/API/Web_Authentication_API

Form a group of max two members and send me an email with your group information by April 24, 2026.

The deadline of the project submission is May 8, 2026.

There will be a viva session with project showcasing at a date announced later.

Submit the project using this Google form: <https://forms.gle/jcrw6fTXzcwsZrmo8>